

End-to-End Red Team Capstone

Planning, Scope, Attack-Path Reasoning, Evidence, Detection Validation, Cleanup, and Final Delivery

Learning objectives

- Menggabungkan seluruh Module 00-25 menjadi satu engagement workflow yang disiplin, repeatable, dan aman.
- Membuat scope, objective, stop conditions, evidence plan, dan success criteria sebelum menyentuh target lab.
- Menyusun hypothesis-driven attack path dari observation, bukan menjalankan tool secara acak.
- Membedakan validated, blocked, detected, logged-only, hypothetical, dan not-tested pada setiap step campaign.
- Menutup engagement dengan cleanup, evidence integrity, report QA, remediation priorities, dan handoff profesional.

Prerequisites & tooling

- Module 00-25 selesai, khususnya Scope/RoE, Enumeration, Web/API, Exploitation Fundamentals, PrivEsc, AD, Pivoting, ATT&CK, OPSEC, dan Reporting.
- Omarchy / Arch Linux, Python 3, jq, sha256sum, Markdown editor. Optional: isolated GOAD/MINILAB atau hosted lab yang memberi authorization eksplisit.

omarchy pkg add python jq ripgrep

Final-module principle - Tujuan capstone bukan “mendapat shell sebanyak mungkin”. Tujuannya menunjukkan bahwa lo bisa menjalankan assessment secara terkontrol: objective jelas, teknik relevan, bukti cukup, risiko dapat dijelaskan, cleanup selesai, dan report dapat dipertanggungjawabkan.

1. Capstone Mindset: Dari Tool User Menjadi Operator

Operator yang matang tidak memulai dari command. Ia memulai dari objective, constraints, available evidence, dan hypothesis. Setiap aksi harus menjawab pertanyaan: “Apa yang ingin gue validasi, apa outcome yang mungkin, apa telemetry yang muncul, dan kapan gue harus berhenti?”

Level	Pertanyaan utama
Objective	Apa yang ingin dibuktikan terhadap business/security control?
Hypothesis	Jalur apa yang masuk akal berdasarkan evidence saat ini?
Action	Teknik minimum apa yang diperlukan untuk menguji hypothesis?
Observation	Apa yang benar-benar terjadi?
Decision	Lanjut, pivot, stop, atau dokumentasikan limitation?
Evidence	Bukti minimum apa yang mempertahankan reproducibility?
Outcome	Blocked / detected / logged-only / validated / hypothetical / not-tested?

Anti-pattern - Jangan “scan semuanya, exploit semua yang bisa, lalu baru cari cerita”. Capstone ini menilai reasoning, safety, evidence quality, dan keputusan operator lebih tinggi daripada jumlah teknik.

2. Scenario: Northstar Labs

Package Module 26 menyediakan scenario sintesis bernama Northstar Labs. Default track sepenuhnya offline: lo menganalisis evidence contoh, membangun attack path, memilih validasi yang masuk akal, membuat timeline, findings, detection notes, dan final report tanpa menghubungi sistem eksternal.

Asset	Role	Synthetic address / identity
edge-web01	Public-facing training web app	10.26.10.20 / web01.northstar.test
app01	Internal application server	10.26.20.20 / app01.northstar.test
dc01	Training domain controller	10.26.20.10 / dc01.northstar.test
ws01	User workstation	10.26.30.10 / ws01.northstar.test
analyst01	SOC analyst identity	analyst01@northstar.test
jordan	Standard user identity	jordan@northstar.test

Semua nama, IP, token, identities, logs, dan findings di package adalah dummy/synthetic. Suffix `.test` dan private IP sengaja dipakai agar tidak menunjuk ke target nyata.

2.1 Engagement objectives

ID	Objective	Success condition
OBJ-01	Map externally reachable training surface	Asset/service map memiliki source evidence dan no out-of-scope host.
OBJ-02	Validate one initial-access weakness	Weakness tervalidasi di lab/synthetic evidence tanpa destructive action.
OBJ-03	Reason about privilege path	Minimal satu path dari low privilege ke higher-impact identity/resource dengan validated vs hypothetical labels.
OBJ-04	Evaluate defensive visibility	Setiap tested step diberi detection outcome dan telemetry prerequisite.
OBJ-05	Deliver professional report	Evidence, findings, attack path, remediation, limitations, cleanup, dan QA lengkap.

3. Rules of Engagement & Safety Gates

Sebelum live lab, tulis scope sebagai data yang bisa divalidasi. Package menyediakan `scope-guard.py` yang menolak public IP dan hostname di luar suffix lab/test. Ini bukan pengganti authorization; ia hanya guardrail tambahan agar operator tidak salah target.

python labs/scope-guard.py labs/scenario.json

Gate	Pass condition
Authorization	Target adalah lab milik sendiri, CTF, atau platform dengan authorization eksplisit.
Scope	Semua IP/hostname ada di scope file dan private/loopback/test-only.
Time window	Jam testing dan timezone diketahui.
Data handling	No real credentials/PII; evidence folder private; secrets tidak di-commit.

Stop conditions	Availability issue, unexpected public target, sensitive data, or scope ambiguity => stop.
Cleanup	Temporary accounts/files/listeners/changes punya owner dan rollback plan.

Production habit - Kalau scope ambigu, stop dan klarifikasi. “Sepertinya ini masih target gue” bukan authorization.

4. Engagement Workflow

Plan -> Scope Guard -> Baseline -> Recon/Enumeration -> Hypothesis -> Minimal Validation
-> Privilege/Path Reasoning -> Detection Review -> Evidence/Timeline
-> Cleanup -> Findings -> Executive Narrative -> QA -> Delivery

4.1 Baseline sebelum testing

- Catat date/time UTC, operator identity, source IP/VPN context, target list, tool versions, dan workspace hash state.
- Pisahkan raw evidence, normalized notes, findings, report draft, dan delivery artifacts.
- Buat objective tracker dari awal; jangan menunggu akhir engagement untuk mengingat apa yang sudah dilakukan.

4.2 Hypothesis-driven testing

Observation	Hypothesis	Minimum validation
Web response exposes predictable object IDs	Authorization mungkin object-level, bukan owner-level	Bandingkan dua dummy identities/objects di lab; no bulk enumeration.
Service account punya broad access	Compromise account dapat memperluas reach	Map permissions and dependencies; validate only if explicitly in scope.
Workstation telemetry shows process creation but no alert	Control mungkin logged-only	Correlate event timestamp, sensor health, rule coverage, and analyst workflow.
Nested group reaches privileged group	Privilege inheritance may create path	Resolve membership/ACL chain; do not assume impact until validated.

5. Attack-Path Reasoning

Attack path adalah chain of conditions. Setiap edge harus punya evidence, confidence, dan state. Satu edge hypothetical tidak boleh membuat seluruh chain dilaporkan sebagai validated.

State	Makna
Validated	Step dilakukan di authorized lab dan outcome observed.
Blocked	Control mencegah step; bukti control dicatat.
Detected	Telemetry + analytic/alert/response tervalidasi.
Logged-only	Telemetry ada, tetapi tidak ada analytic/response yang relevan.
Hypothetical	Masuk akal dari data, tetapi sengaja tidak diuji.
Not-tested	Tidak diuji karena RoE, waktu, risiko, dependency, atau authorization.

5.1 Example chain

```
Internet -> edge-web01 [validated exposure]
edge-web01 -> app01 [hypothetical internal trust]
app01 -> svc_app [validated service identity mapping]
svc_app -> privileged group [blocked by ACL / no effective write]
privileged group -> dc01 [not-tested]
```

Dalam narrative, chain ini tidak boleh ditulis “domain compromise possible” hanya karena node akhir privileged. Report harus menekankan edge yang gagal/blocked dan residual risk yang masih nyata.

6. Detection-Aware Validation

Module 24 memperkenalkan detection-aware operations. Di capstone, setiap step punya expected telemetry dan actual outcome. Ini membuat assessment berguna bagi SOC, bukan hanya vulnerability owners.

Step	Expected telemetry	Outcome example
Web authz test	Reverse proxy/app access logs	Logged-only; no alert expected.
Process execution in lab endpoint	EDR process event + parent/child	Detected; analytic fired within 30s.
Read-only AD query	LDAP/DC audit telemetry depending policy	Telemetry present; no dedicated analytic.
Blocked privilege action	OS/security log + control event	Blocked by policy; no privilege change occurred.

Evidence rule - “Tidak ada alert” bukan bukti detection failure kalau sensor health, data source, ingestion delay, rule coverage, dan timestamp correlation belum diverifikasi.

7. Evidence, Timeline, and Chain of Custody

Capstone membutuhkan timeline. Package menyediakan `timeline.py` untuk append event yang sudah disanitasi. Jangan masukkan password, token, ticket, private key, atau data real ke tool ini.

```
python labs/timeline.py add module26-capstone/03-notes/timeline.csv --phase enumeration --asset app01.northstar.test --
action "reviewed synthetic service inventory" --outcome validated
```

Folder	Isi
00-scope	Scenario, authorization note, targets, stop conditions.
01-raw	Raw synthetic/live-lab evidence; immutable where possible.
02-normalized	Parsed CSV/JSON/maps derived from raw evidence.
03-notes	Timeline, hypotheses, decisions, limitations.
04-findings	One file per finding + attack-path narrative.
05-report	Executive summary and final report draft.
06-evidence	SHA-256 manifest + evidence index.
07-cleanup	Cleanup checklist and validation evidence.

8. Findings and Risk Communication

Temuan capstone harus menghubungkan root cause -> exploitability/prerequisites -> validated impact -> business relevance -> remediation -> retest. Jangan memberi severity hanya dari nama vulnerability atau scanner score.

Finding QA	Pass condition
Title	Spesifik pada weakness dan affected control.
Scope	Asset/identity benar-benar in-scope.
Evidence	Observation mendukung claim; baseline vs modified state jelas.
Impact	Validated impact dipisah dari potential impact.
Severity	Method/rationale konsisten; CVSS vector hanya jika dibutuhkan.
Remediation	Root-cause fix + validation criteria.
Retest	Fixed/partial/unresolved/not-retested + new evidence.

9. Cleanup and Closeout

Testing belum selesai saat objective tercapai. Engagement selesai setelah environment dikembalikan ke state yang disepakati dan cleanup dapat dibuktikan.

Cleanup item	Evidence
Temporary files / tooling	Path list + removal confirmation.
Temporary accounts / keys	Deleted/disabled status.
Changed configuration	Before/after value or rollback record.
Listeners / tunnels / sessions	Stopped; no residual process/service.
Credentials/tickets	Securely removed from workspace if policy requires.
Evidence retention	Archive/delete date and owner recorded.

Safety stop - Jika cleanup tidak bisa dilakukan karena akses hilang atau environment berubah, dokumentasikan immediately. Jangan mencoba recovery improvisasi yang berada di luar RoE.

10. Hands-on Labs - Offline First

Lab 1 - Initialize workspace

```
./labs/workspace-init.sh module26-capstone
```

Hasil: directory structure, scope note, dan permission private.

Lab 2 - Validate scenario scope

```
python labs/scope-guard.py labs/scenario.json
```

Expected: seluruh target private dan `.test`; script gagal jika public IP/suffix tidak diperbolehkan.

Lab 3 - Load synthetic evidence

```
cp -a labs/sample-evidence/. module26-capstone/01-raw/
find module26-capstone/01-raw -type f -maxdepth 1 -print
```

Review `web-observations.json`, `ad-observations.json`, `detections.csv`, dan `service-inventory.csv`. Bangun minimal tiga hypotheses.

Lab 4 - Objective tracker

```
python labs/objective-tracker.py init labs/scenario.json module26-capstone/03-notes/objectives.csv
python labs/objective-tracker.py set module26-capstone/03-notes/objectives.csv OBJ-01 done --note "synthetic surface map completed"
python labs/objective-tracker.py show module26-capstone/03-notes/objectives.csv
```

Lab 5 - Timeline

```
python labs/timeline.py add module26-capstone/03-notes/timeline.csv --phase analysis --asset edge-web01.northstar.test --
action "reviewed baseline web evidence" --outcome validated
```

Lab 6 - Create finding stub

```
python labs/finding-stub.py F-001 "Object authorization inconsistency in training API"
module26-capstone/04-findings/F-001.md
```

Isi evidence, prerequisites, impact, remediation, and retest fields dari data synthetic. Jangan menulis claim yang tidak didukung evidence.

Lab 7 - Attack-path map

```
python labs/attack-path-map.py labs/attack-path.json module26-capstone/04-findings/attack-path.md
```

Tool hanya merender graph dari JSON synthetic; tidak melakukan network activity.

Lab 8 - Evidence manifest

```
./labs/evidence-manifest.sh module26-capstone
```

Lab 9 - Engagement QA

```
python labs/engagement-qa.py module26-capstone
```

QA memeriksa scope marker, objective tracker, timeline, findings, evidence manifest, placeholder text, dan pola secret umum. Ia bukan DLP/secret scanner lengkap.

11. Optional Live-Lab Lane

Setelah offline capstone selesai, lo boleh mengulang workflow pada lab sendiri seperti GOAD MINILAB, Juice Shop, DVWA, Metasploitable, atau hosted training lab yang memberi authorization. Package Module 26 sengaja tidak mengotomasi exploitation, persistence, credential attacks, atau lateral movement.

Phase	Yang dilakukan di live lab
Scope	Isi target private/test-only dan stop conditions.
Baseline	Capture host/network identity and tool versions.
Discovery	Gunakan teknik dari Module 07-09 sesuai scope.
Validation	Pilih minimal satu weakness dari Module 11-20; lakukan minimum action.
Detection	Catat expected vs actual telemetry bila platform menyediakan visibility.
Cleanup	Rollback temporary state dan capture proof.
Reporting	Selesaikan finding, attack path, executive summary, and remediation plan.

Hard boundary - Jangan menggunakan capstone ini sebagai checklist terhadap internet random, employer/client tanpa RoE, atau aset yang "mungkin punya izin". Live lane hanya untuk environment yang jelas authorized.

12. Final Capstone Deliverables

Artifact	Minimum acceptance criteria
Scope & RoE note	Targets, exclusions, time window, data handling, stop conditions.
Asset map	In-scope only; source evidence for each asset.
Objective tracker	Status + note + limitation for every objective.
Timeline	Timestamped operator decisions and material observations.
Attack-path map	Every edge labeled validated/blocked/detected/logged-only/hypothetical/not-tested.
Findings	At least 2 high-quality findings or 1 finding + 1 validated control success.
Detection table	Expected telemetry, actual telemetry, alert/response, gaps.
Cleanup record	Temporary changes removed or exceptions documented.
Report	Executive summary + scope + method + path + findings + remediation + limitations.
Evidence manifest	SHA-256 hash list for all retained evidence.

12.1 Scoring rubric - 100 points

Area	Points	What earns full credit
Scope & safety	15	No out-of-scope action; clear gates/stop conditions.
Reasoning	20	Hypothesis-driven decisions; no tool spam.
Technical accuracy	20	Claims match evidence; prerequisites understood.
Evidence & timeline	15	Traceable, minimal, hashed, timestamped.
Detection awareness	10	Telemetry prerequisites and outcomes correctly separated.
Cleanup	5	Rollback verified; exceptions documented.
Reporting	15	Findings and executive narrative are clear, actionable, and defensible.

Recommended pass: 80/100, dengan mandatory pass pada Scope & Safety. Nilai tinggi tidak bisa menutupi scope violation.

13. Operator Debrief

Setelah capstone, tulis one-page debrief. Ini penting karena operator yang berkembang cepat bukan yang tidak pernah salah, tetapi yang bisa mengubah friction menjadi process improvement.

- Tiga keputusan terbaik yang dibuat dan evidence yang mendukungnya.
- Tiga hal yang hampir membuat scope/evidence/assumption salah.
- Technique yang terlalu noisy atau tidak memberikan value.
- Control yang bekerja dan bagaimana membuktikannya.
- Data yang seharusnya dikumpulkan lebih awal.
- Apa yang akan diubah pada runbook engagement berikutnya.

14. Graduation Checklist

Capability	Self-check
Legal/ethical	Bisa menjelaskan scope, authorization, RoE, data handling, stop conditions.
Linux/Windows/network/web	Bisa mengumpulkan evidence dasar tanpa kehilangan konteks.
Enumeration	Bisa memetakan target secara sistematis dan evidence-driven.
Vulnerability validation	Bisa membedakan signal, hypothesis, validation, and impact.
Privilege/AD	Bisa menjelaskan path dan prerequisites tanpa mengandalkan tool graph secara buta.
Pivoting/C2/OPSEC	Paham network path, telemetry, cleanup, dan detection implications.
Reporting	Bisa menulis finding/report yang reproducible, safe, dan actionable.
Professional behavior	Tahu kapan harus stop, escalate, document limitation, dan meminta clarification.

You are ready for the next stage - Setelah Module 26, fokus berikutnya bukan menambah command sebanyak-banyaknya. Bangun jam terbang melalui platform authorized, tulis report untuk setiap lab, review ATT&CK/telemetry, dan ulang capstone sampai workflow terasa natural.

15. References

NIST SP 800-115 - Technical Guide to Information Security Testing and Assessment

<https://csrc.nist.gov/pubs/sp/800/115/final>

MITRE ATT&CK - Enterprise Matrix

<https://attack.mitre.org/matrices/enterprise/>

OWASP Web Security Testing Guide

<https://owasp.org/www-project-web-security-testing-guide/>

OWASP API Security Top 10

<https://owasp.org/API-Security/>

FIRST CVSS v4.0

<https://www.first.org/cvss/v4-0/>

Orange Cyberdefense GOAD

<https://github.com/Orange-Cyberdefense/GOAD>

OffSec Reporting Guidance / Exam documentation

<https://help.offsec.com/>